SOC L1 LAB · INC-003

INC-003 Detection Rules

Two rules for the gap between a file landing and a command running

INCIDENT	INC-003 — Web shell detection rules
REPORT DATE	2026-11-01
CLASSIFICATION	Lab exercise — sanitized for publication
ENVIRONMENT	Wazuh 4.14.7 · Debian 12 · QEMU/KVM
SEVERITY	High

Independent portfolio lab. No production systems, client data, or real credentials.

Contents

1. Inventory
2. The rules
3. Rule-by-rule
4. Test matrix
5. Coverage gaps
6. Tuning
7. Deployment
8. MITRE ATT&CK
9. Caveats

These are the two Wazuh rules added for INC-003. Both were loaded in 4.14.7 and tested against live nginx and PHP-FPM traffic on 2026-10-31.

The deployed file is `rules/local_rules.xml`.

---

1. Inventory

ID	Trigger	Level	MITRE
100127	`.php?cmd=` in an access-log request	12	T1505.003, T1059.004
100128	`.php` file added or modified in a FIM path	12	T1505.003

---

2. The rules

```
<group name="local,web,">

  <rule id="100127" level="12">
    <if_sid>31100</if_sid>
    <match>.php?cmd=</match>
    <description>Web: command parameter in a PHP request (possible web shell)</description>
    <mitre>
      <id>T1505.003</id>
      <id>T1059.004</id>
    </mitre>
    <group>web,attack,</group>
  </rule>

</group>

<group name="local,syscheck,">

  <rule id="100128" level="12">
    <if_sid>550,554</if_sid>
    <match>.php</match>
    <description>FIM: PHP file added under a monitored path (possible web shell)</description>
    <mitre>
      <id>T1505.003</id>
    </mitre>
    <group>syscheck,web,persistence,</group>
  </rule>

</group>
```

---

3. Rule-by-rule

100127 — `.php?cmd=` request

- **Parent:** stock **31100**, the level-0 "access log messages grouped" rule. Without a parent, the rule would fire on the raw log before the web decoder runs.
- **Match:** the literal substring `.php?cmd=`.
- **Tested:** 22:12:25 on `GET /updates2.php?cmd=id`; 22:12:28 on the same request with a `sqlmap/1.7` user-agent.
- **Why literal:** Wazuh uses one `<match>` per rule; two `<match>` tags are not ANDed. `\.php.*cmd=` via `<regex>` did not match the access log. The literal is the reliable form.
- **False positives:** a legitimate PHP application that uses `cmd` as the first query parameter. Allow-list the path or the parameter name if that is normal for the app. Referer and User-Agent text containing `.php?cmd=` does **not** trigger it; the match is scoped to the request path.
- **Gaps:** `?foo=1&cmd=id` does not match; POST bodies are not in the access log; `.phtml`, `.php5`, and framework routes are not covered.

100128 — PHP file added or modified

- **Parents: 550** (checksum changed) and **554** (file added).
- **Match:** `.php` in the FIM log.
- **Tested:** 22:12:20.956 (`updates2.php` added) and 22:14:11.305 (`test.php` modified). Both fired.
- **False positives:** legitimate PHP deployments and updates, **staging copies**, and backup/temp files (`index.php.bak`, `index.php.tmp`) because `.php` is a substring. Match them to a change ticket; do not suppress the rule. If backups are routine, exclude `*.php.bak` and `*.php.tmp` in the FIM configuration.
- **Gaps:** `.phtml`, `.php5`, `.phar`, and files added outside FIM-monitored paths. It also fires for a PHP file added anywhere under `/etc`, `/home`, or the webroot, not just the webroot.

---

4. Test matrix

Action	Expected
`GET /index.html`	31100 only
`GET /updates.php?page=1`	31100 only
`GET /updates.php?cmd=id`	**100127**
`GET /index.html?cmd=view`	31100 only
FIM add `/var/www/html/updates2.php`	**100128**
FIM modify `/var/www/html/test.php`	**100128**
FIM add `/var/www/html/index.html`	no 100128

Logged tests:

```
22:12:20.956  100128  /var/www/html/updates2.php added
22:12:25.031  100127  GET /updates2.php?cmd=id 200
22:12:28      100127  GET /updates2.php?cmd=id 200 (sqlmap UA)
22:14:11.305  100128  /var/www/html/test.php modified
```

---

5. Coverage gaps

The rules catch the common `cmd=` shell and any new PHP file. They do not catch:

- a shell using `exec=`, `command=`, `shell=`, or a cookie/header parameter;
- a shell with a `.phtml` or `.php5` extension;
- a POST-only shell, because the access log has no request body;
- a framework route that dispatches to a shell without a `.php` path;
- an obfuscated payload with no readable parameter name.

Those need application logs, a WAF, or a decoder that inspects the request body. State this in the ticket rather than implying the rules are complete.

---

6. Tuning

- Add literals for other common parameters and extensions as separate rules; do not attempt to combine them in one `<match>`.
- Keep the level at 12. A web shell is remote code execution as the web user.
- Match legitimate deployments to a change ticket. A pipeline that writes PHP should produce an expected FIM event; the analyst needs the ticket ID, not a suppression.
- Pair with a read-only webroot and `disable_functions` so the detection is not the only control.

---

7. Deployment

```
cd "$HOME/wazuh-docker/single-node"
docker compose up -d wazuh.manager
sleep 20

for id in 100127 100128; do
  printf '%s: ' "$id"
  docker exec single-node-wazuh.manager-1 \
    grep -c "id=\"$id\"" /var/ossec/etc/rules/local_rules.xml
done
```

Test 100127 without a browser:

```
echo '10.0.2.2 - - [31/Oct/2026:22:12:24 +0000] "GET /updates2.php?cmd=id HTTP/1.1" 200 31 "-"
"curl/8.22.0"' \
 | docker exec -i single-node-wazuh.manager-1 /var/ossec/bin/wazuh-logtest 2>&1 \
 | grep 100127
```

Test 100128 by creating a `.php` file under `/var/www/html` and checking the alert.

---

8. MITRE ATT&CK

Technique	ID	Rule
Server software component: web shell	T1505.003	100127, 100128
Unix shell	T1059.004	100127
Ingress tool transfer	T1105	not covered by these rules
System discovery	T1082, T1033	the shell's commands, via audit 80792

---

9. Caveats

- Tested on nginx 1.22.1 with PHP-FPM 8.2 on Debian 12. A different web server may need a different parent rule than 31100.
- The access log must be collected with a web log format; the lab uses the `apache` format for nginx.
- A `200` response is not evidence of benign activity. That is the whole lesson of INC-003.